- Compute Match — Security, Observability, Salesforce Integration and Testing
  - Security model
  - Observability
  - Salesforce integration (ADR-001)
  - Testing

Compute Match — Security, Observability, Salesforce Integration and Testing

Security model

- **Delivery identity:** GitLab OIDC with Google Workload Identity Federation; separate Google service accounts for plan, apply, deploy, verify and Keycloak.
- **Runtime identity:** Kubernetes service accounts mapped to Google service accounts; secrets from Secret Manager with least privilege; Cloud SQL Auth Proxy; separate database roles (for example the audit-retention role can only SELECT and DELETE).
- **Network:** NetworkPolicies, private Cloud SQL and Redis, Cloud Armor and Gateway at the edge.
- **Application:** Keycloak JWTs with audiences per client (`customer-web` , `workflow-worker` , `audit-listener` …). Internal Salesforce and audit endpoints only accept a pinned caller `client_id` . CSV cells are sanitized against formula injection. Personal email domains are blocked.
- **Repository:** protected `main` , CODEOWNERS, secret scanning (gitleaks, trufflehog, talisman), no secrets in manifests or docs.
- **Audit:** Keycloak login/logout events and domain actions are written to an audit log, kept about 13 months then purged by `AuditRetentionWorkflow` .

Observability

- **Logs:** every owned service writes JSON Lines to stdout using **Log Record v2** (`docs/architecture/logging/log-record-v2.md`): `log_schema_version: 2` , severity, `event_name` ,

resource, source, optional trace context, attributes and exception. Unsafe fields are redacted; no PII or secrets in attributes.

- **Event catalog** (`docs/architecture/logging/event-catalog.md`): for example `workflow.started` , `workflow.completed` , `workflow.failed` , `reservation.request.*` , `csv_import.*` , `provider_onboarding.*` , `integration.salesforce.failed` , `notification.delivery.failed` , `authorization.denied` .
- **Traces and metrics:** OpenTelemetry in frontend, backend, worker (Temporal TracingInterceptor) and Keycloak. In GCP the Helm `otel-collector` exports to Google Cloud; logs go to Cloud Logging. Locally, optional SigNoz (`make obs-start` , UI on port 3301).
- Runbooks: `docs/operations/*-observability.md` for backend, frontend, worker, Keycloak, Superset and gateway.

Salesforce integration (ADR-001)

- **Direction:** one-way, Compute Match → Salesforce **Offtake** object (`Offtake_Request__c`).
- **Pattern:** transactional outbox table `salesforce_create_sync` , drained by Temporal `SfdcCreateBatchWorkflow` which calls backend internal APIs (domain stays in the backend). No Kafka or Pub/Sub.
- **Granularity:** one Offtake per NCP offering (external id `Reservation_Request_Offering_Id__c`); open custom requests get one create-only Offtake keyed by the request id.
- **Jobs:** nightly **create** (05:00 UTC, full projection) and **status** every 2 minutes (status and, when Contracted, negotiated terms). Upserts use the sObject Collections external-id API, up to 200 records per call.
- **Reliability:** outbox states PENDING, SYNCED, FAILED; retries for Salesforce outages; mandatory failure summary email; audit events `SFDC_OFFTAKE_SYNCED` / `SFDC_OFFTAKE_SYNC_FAILED` written atomically with the outbox.
- **Toggles:** `SFDC_SYNC_ENABLED` ; partner-domain read sync separately with `SFDC_PARTNER_DOMAIN_SYNC_ENABLED` .

Testing

Layer	Tooling	Command
Backend	pytest, TestContainers	`make test-backend`
Frontend	Jest 30, React Testing Library, jest-axe	`make test-frontend` (`npm run test` , `test:a11y` , `quality-gate`)

Layer	Tooling	Command
Workflows / worker	pytest	`make test`
End-to-end	Playwright + Cucumber (Gherkin) in `e2e_playwright/`	see its README

E2E features cover Authentication, CustomerWorkflow, ProviderWorkflow and AdminWorkflow, using page objects in `src/PageObjects/` and step definitions in `src/Specs/`. Choose the target with `TEST_ENV` (`local`, `computematch-dev`, `computematch-qa`, `computematch-stg`). Secrets go in a Git-ignored `.env.local`. HTML reports are written to `reports/`. `make verify` does not run the E2E suite.